

# Evasion & Detection: Analisi di un attacco Reverse Shell via Portmap Tunneling

## 🚒 Descrizione del Progetto

Questo progetto documenta un attacco simulato in un ambiente virtuale controllato. L'obiettivo è dimostrare come un attaccante possa stabilire una connessione persistente verso una macchina **Windows 11 con Microsoft Defender attivo**, utilizzando un loader personalizzato in C#, certificati digitali per l'evasione e un tunnel **Portmap.io** per superare i limiti della rete esterna e rendere l'attacco il più "reale" possibile.

Il monitoraggio e l'analisi post-compromissione sono stati effettuati tramite **Security Onion**.

## 🔧 Stack Tecnologico

- **Attacker OS:** Kali Linux (Rete Esterna via Portmap)
- **Victim OS:** Windows 11 (Defender Attivo)
- **SIEM/IDS:** Security Onion (Elasticsearch, Kibana, Hunt)
- **Tools:** Metasploit Framework, Mono (compiler), OpenSSL (certificati), C# (Loader).

## 🚀 Fasi dell'Attacco

### 1. Preparazione del Payload e Evasione

Per bypassare le firme statiche di Defender, non è stato usato un classico .exe generato da msfvenom.

- **Payload:** shell\_reverse\_tcp (scelto per stabilità durante il tunneling).
- **Loader C#:** È stato scritto un "loader" in C# che richiama il file grezzo (raw) del payload.
- **Compilazione & Firma:** Il codice è stato compilato con mono. Per eludere i controlli di reputazione, il binario è stato firmato con certificati digitali (Self-signed/Valid).

**Nota tecnica:** L'uso di reverse\_https sarebbe stato ancora più efficace grazie alla cifratura del traffico, rendendo difficile l'ispezione dei pacchetti da parte di un IDS.

### 2. Bypass del Networking (Portmap.io)

L'attaccante si trova in una rete esterna. È stato configurato un tunnel TCP su Portmap per mappare la porta locale della Kali su un indirizzo pubblico, permettendo al payload di "chiamare verso casa" attraverso il firewall della vittima.

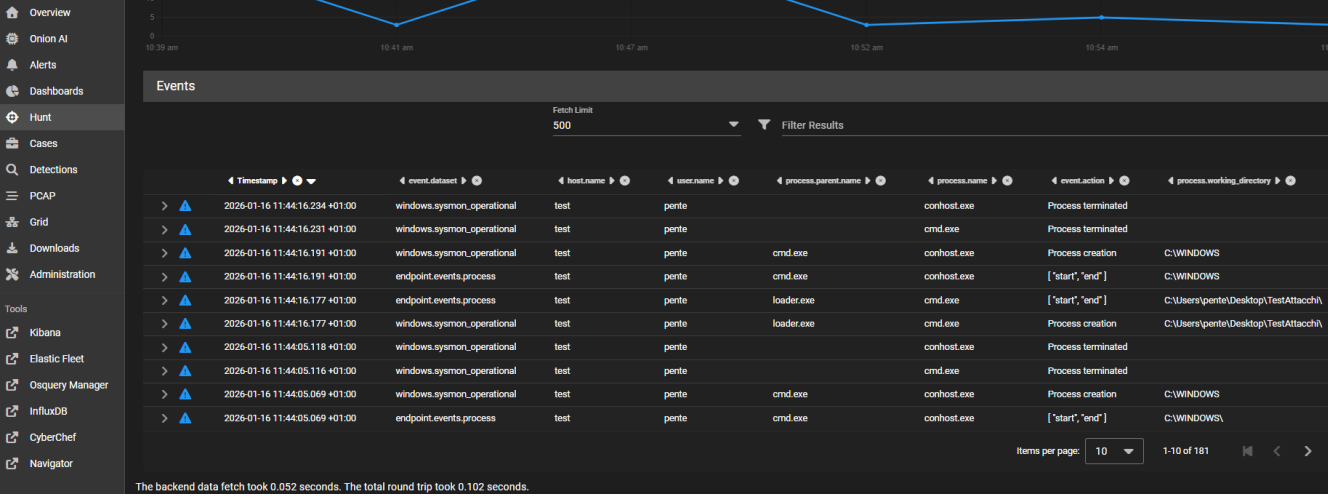
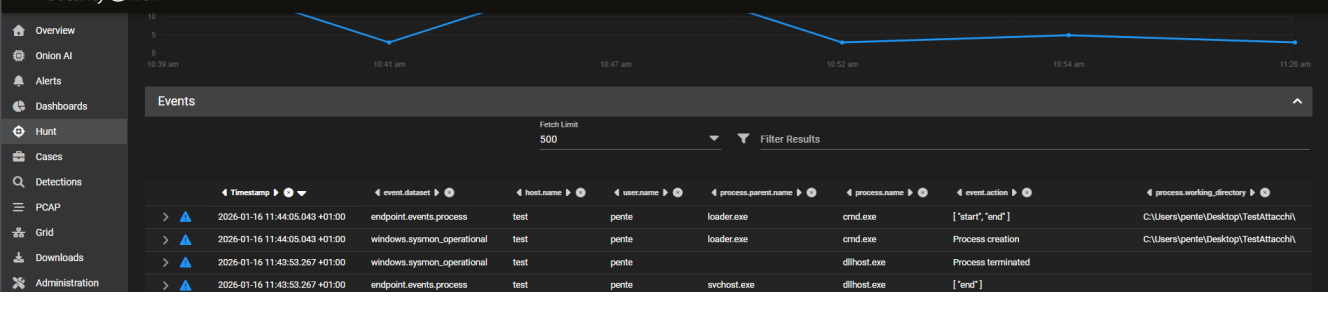
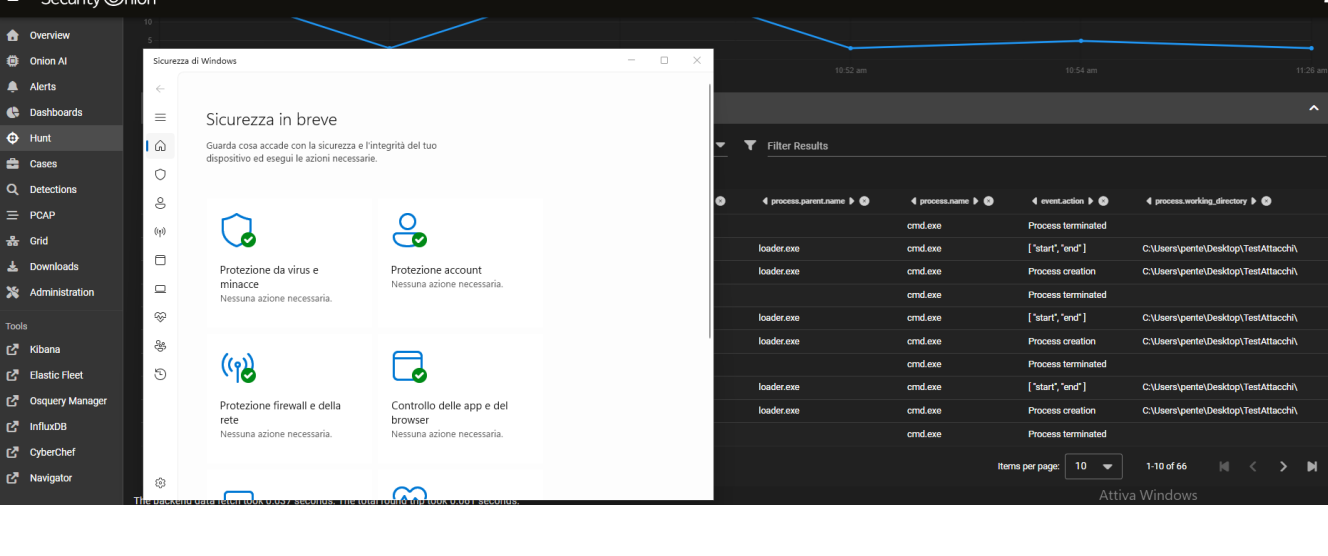
### 3. Esecuzione e Sessione

Una volta eseguito loader.exe sul desktop della vittima, la sessione viene stabilita con successo nonostante le protezioni attive.

## 🔍 Analisi Forense (Security Onion)

L'attività è stata interamente tracciata all'interno di **Security Onion**. Di seguito l'analisi dei log tramite la funzione **Hunt**.

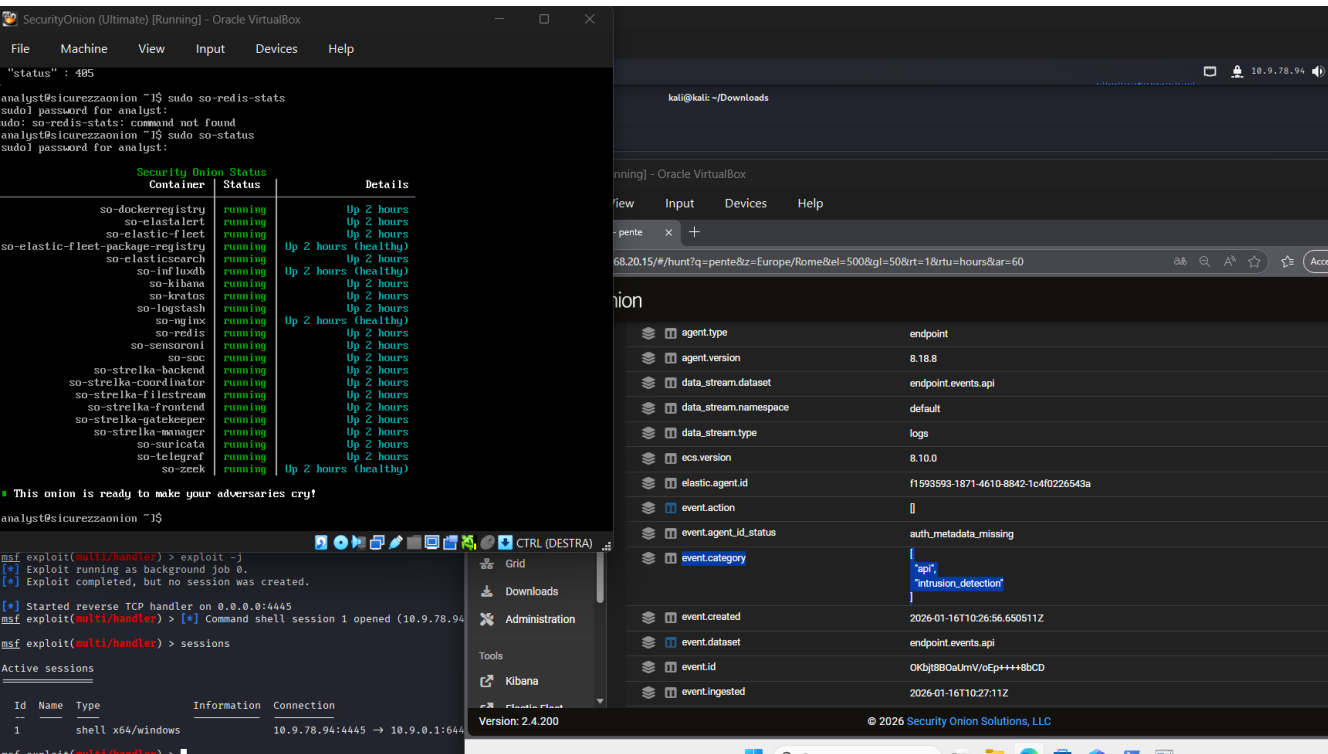
### Analisi dei Processi



Dalle evidenze raccolte, possiamo osservare la catena di esecuzione:

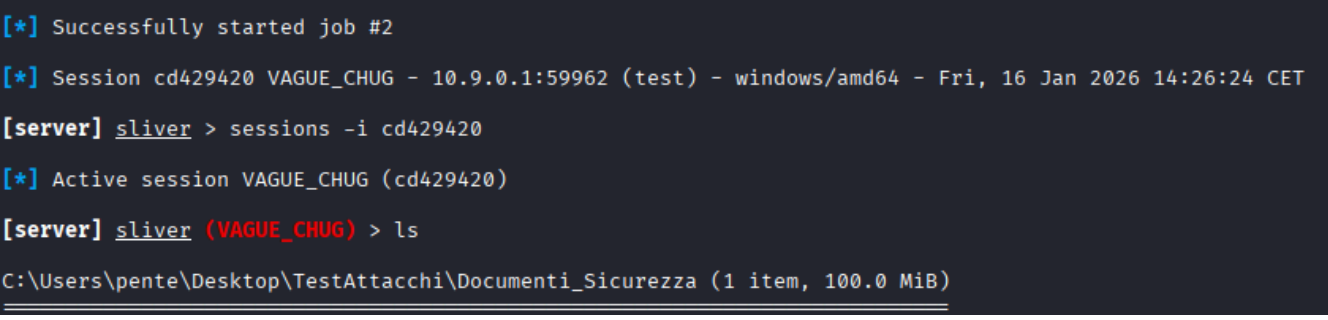
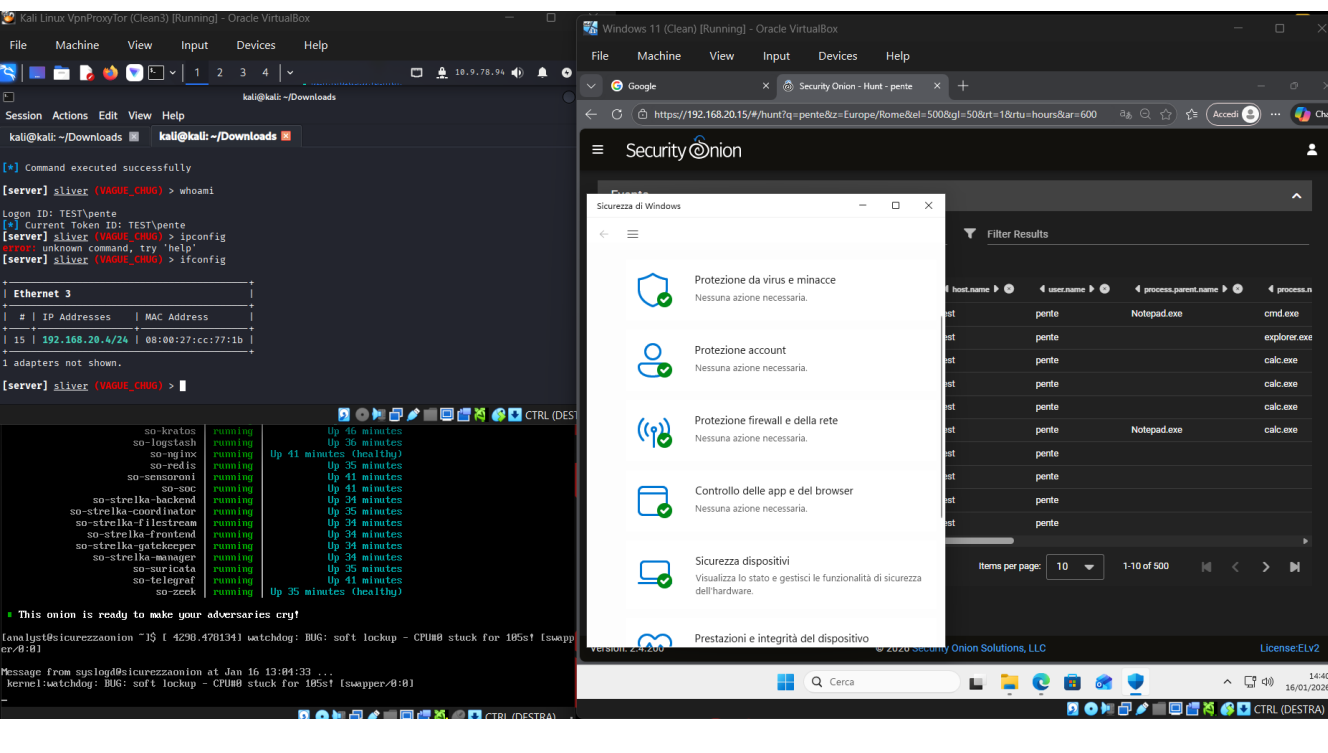
1. **Process Creation:** Il file loader.exe viene eseguito dall'utente pente.
2. **Parent-Child Relationship:** Si nota come loader.exe generi un processo cmd.exe. Questo è un indicatore di compromissione (IoC) tipico di una reverse shell.
3. **Monitoraggio Sysmon:** I log mostrano chiaramente l'azione Process creation e la successiva Process terminated relative a cmd.exe e conhost.exe.

### Rilevamento Intrusioni



Security Onion ha classificato l'evento sotto la categoria intrusion\_detection. Nonostante l'evasione dell'antivirus (endpoint), il traffico di rete o il comportamento del processo ha attivato gli alert del SIEM.

| Timestamp | Event Dataset              | Hostname | User  | Process Parent | Process Name | Action    |
|-----------|----------------------------|----------|-------|----------------|--------------|-----------|
| 11:44:05  | endpoint.events.process    | test     | pente | loader.exe     | cmd.exe      | start/end |
| 11:44:16  | windows.sysmon_operational | test     | pente | cmd.exe        | conhost.exe  | creation  |



### Evoluzione dell'Attacco: Sliver C2 Framework

Dopo la fase iniziale, l'attacco è stato scalato utilizzando **Sliver**, un framework C2 in Go, per testare capacità di post-esplorazione più avanzate.

- **Payload & Protocollo:** È stata generata una sessione configurata per comunicare sulla porta 4445.
- **Sessione Attiva:** Come mostrato negli screenshot, è stata stabilita con successo la sessione sul target.
- **Interazione & Recon:** Una volta stabilita la sessione, sono stati eseguiti comandi di ricognizione:
- **Persistence & Stealth:** Mentre Defender risultava attivo e "senza azioni necessarie", la sessione Sliver rimaneva operativa, dimostrando l'efficacia dell'implant nell'operare in memoria (in-memory execution).

## 📊 Risultati e Conclusioni

L'attacco ha dimostrato che:

1. **Defender non è infallibile:** Un binario compilato ad hoc e firmato può bypassare le protezioni basate su firme.
2. **L'importanza del monitoraggio:** Anche se l'antivirus fallisce, un SIEM configurato correttamente (Security Onion) permette di identificare l'anomalia analizzando la telemetria dei processi (loader.exe -> cmd.exe).
3. **Opacità del traffico:** L'uso di una shell TCP semplice è visibile. Il passaggio a HTTPS (come ipotizzato) renderebbe il rilevamento a livello di rete molto più complesso.